UAT-11985: A Detection Engineering Analysis of AI-Assisted Event Lures Delivering Real-Time Google AitM Phishing

Abstract

Cisco Talos published a threat spotlight on 8 October 2026 documenting an advanced persistent threat spear-phishing campaign tracked as UAT-11985, targeting individuals affiliated with Taiwan research organisations. The campaign combined AI-assisted content generation, institutional impersonation, QR code phishing, and a real-time adversary-in-the-middle phishing kit impersonating Google authentication pages. The threat actor fabricated sender identities purporting to represent the Taiwan European Union Centre, the NCCU Institute of International Relations, and the Taiwan Research Institute, using legitimate public event information as cover. The phishing kit employed a dual-channel architecture using HTTP POST for credential exfiltration and WebSocket for real-time command and control, enabling the interception of credentials and multi-factor authentication challenges. Talos assessed with moderate confidence that the kit's user interface was originally developed in Simplified Chinese and later adapted for Traditional Chinese and English. This working paper translates the observable behaviours described in the source into detection opportunities mapped to four Sigma rules, identifies what remains invisible to network and email defenders, and notes the limitations of a pack built solely from a published writeup without access to underlying telemetry or live infrastructure.

What happened

In mid-2026, Cisco Talos observed an APT spear-phishing campaign targeting Taiwan-based research organisations. The threat actor impersonated legitimate institutions including the Taiwan European Union Centre, the NCCU Institute of International Relations, and the Taiwan Research Institute. An email recipient contacted the organisations concerned to verify the purported senders, but none of the organisations could confirm that the three senders were employees or representatives of the institutions named in the emails. This suggested that the threat actor fabricated the sender identities while using legitimate organisational names and publicly available event information as cover.

The phishing emails exhibited highly consistent structure, rhetoric, and personalisation patterns. Talos stated that the emails "suggesting the threat actor likely used AI-assisted content generation to rapidly customize invitation lures for different targets while maintaining a common social engineering framework." All three emails followed a three-part structure. The opening section provided a polished but overly elaborate description of geopolitical or policy context, relying on "grandiose yet vague expressions such as 'the global strategic landscape,' 'reshaping the great-power order,' 'three-dimensional analysis,' 'forward looking and in-depth analysis,' and 'high intensity professional dialogue' to create an impression of academic authority and subject matter expertise." The second section was customised for the recipient and used targeted flattery, with "similar phrases including 'admiration,' 'authoritative perspective,' 'highly perceptive,' and 'key practical dimensions' appear[ing] across the three messages." The final section presented event logistics including topic, date, venue, and registration instructions, much of which appeared to have been copied from legitimate institutional websites or public event announcements.

Talos noted that "several invitation emails exhibited nearly identical syntactic structures despite discussing different geopolitical topics, suggesting the content was generated from a reusable prompt template rather than independently authored." While Talos "cannot conclusively determine whether

the emails were fully generated by a large language model (LLM), the campaign demonstrates strong evidence of AI-assisted content production and personalisation." The source explicitly stated that "although these linguistic indicators alone cannot conclusively prove the use of generative AI, their consistency across all three emails suggests that the threat actor likely used an AI-assisted template to produce and personalize the phishing lures at scale."

The registration links embedded in the emails did not direct recipients to the legitimate event registration pages they seemed to represent. Talos observed that "one hyperlink displays a legitimate-looking Google Forms URL, while its underlying href redirects the recipient to a deceptive phishing site hosted on a third-party platform." The actor also attached event posters to several phishing emails. While the poster designs were scraped from legitimate websites, the embedded QR codes were maliciously altered. Talos assessed that "this modification indicates a calculated physical world attack vector," noting that the actor may have anticipated that recipients might print and display these posters on office bulletin boards, thereby tricking other individuals into scanning the malicious QR code.

The phishing kit impersonated a legitimate Google Form and appeared visually identical to the authentic service, then forcibly redirected the user to a spoofed Google login page. Talos observed that "the spoofed Google login panels only support Simplified Chinese (zh-CN), Traditional Chinese (zh-TW), and English locales, with region detection based on the victim's browser 'navigator.languages,' strongly suggesting targeting of Chinese-speaking users." The phishing page also revealed a hidden HTML section designed to simulate a successful Google authentication event, containing an iframe with the ID "google-success-frame" configured to load a locally hosted asset at "/google-login-assets/operation-success.html," with the sandbox attribute set to "allow-scripts."

The malicious JavaScript was embedded at the end of the HTML document and relied on advanced string rotation obfuscation. Talos stated that "the script leverages a large, static array of Base64 encoded strings coupled with control flow obfuscation. By utilizing a while(!![]) { push/shift } shuffle loop mechanism, the array rotation is resolved dynamically at runtime, effectively thwarting automated static deobfuscation tools."

The kit employed a dual-channel architecture. For outbound data exfiltration, the threat actor used HTTP POST for stateless, event-driven data transmission, pushing captured data including initial browser fingerprints, credential and challenge submissions, and periodic heartbeat polls. For inbound command and control, the threat actor used WebSocket to provide a low-latency, persistent connection, with the C2 server streaming real-time instructions to the phishing page dictating which MFA challenge screen to render.

The attack chain proceeded through several phases. At the beginning, the threat actor collected device and browser information including locale, user agent, screen dimensions, and mobile-device status, sending this to the actor's HTTP C2 server through a "google_login_start" request. After the server created a session, the JavaScript established a WebSocket connection and received a snapshot containing the current session state. When the victim entered an email address or phone number, the phishing page sent the identifier using the "google_input_identifier" event. The actor's server relayed the identifier to the real Google authentication service to verify whether the account existed and whether a passkey-based flow was enabled. When the victim submitted a password, the phishing page sent the password, account identifier, and browser user-agent information through a "google_login_check" request. The actor's server forwarded the credentials to the real Google authentication service, and if credentials were accepted and Google required additional authentication, the server returned the MFA challenge type and layout, advancing the victim's

interface through WebSocket updates.

Talos assessed with moderate confidence that the user interface localisation was authored by a native Simplified Chinese speaker. The base translation object was written entirely in Simplified Chinese and directly assigned as the zh-CN locale, while Traditional Chinese and English locales were derived from it at runtime via an override or merge function. Lexical choices characteristic of mainland Chinese usage included “ ” for “account” rather than “ ,” “ ” for “computer” rather than “ ,” “ ” for “email/mailbox” rather than “ / ,” “ ” for “incognito browsing window” rather than “ ,” and “ ” for “guest mode.”

The source provided ClamAV signature “Html.Phishing.UAT11985-10060614-0,” Snort2 SID “1:67198,” and Snort3 SID “7:31.” The source stated that indicators of compromise could be found in a GitHub repository but did not list individual IPs, domains, or URLs inline.

Detection opportunities

The source describes several observable behaviours that a defender can act on using network, email, and web telemetry. Each opportunity below is tied to a Sigma rule file named in the detection pack.

Hyperlink href/display mismatch in email. The source establishes that “one hyperlink displays a legitimate-looking Google Forms URL, while its underlying href redirects the recipient to a deceptive phishing site hosted on a third-party platform.” This mismatch is a direct and structural consequence of the credential-harvesting technique, because concealing the true destination is inherent to the approach rather than an optional operator preference. A defender with access to email security gateway or mail proxy logs can compare the visible link text against the underlying href destination. Where the visible text references a legitimate Google Forms URL but the href resolves to a different, non-Google host, this warrants an alert. This maps to ATT&CK T1566.002 (Spearphishing Link) and is captured in the rule file `01-uat-11985-phishing-kit-c2-endpoints.yml`.

Spoofed Taiwan research organisation email. The threat actor impersonated the Taiwan European Union Centre, the NCCU Institute of International Relations, and the Taiwan Research Institute, fabricating sender identities while using legitimate organisational names. The source confirms that none of the organisations could verify the senders as employees or representatives. A defender can monitor inbound email claiming to originate from these institutions where the sending domain or infrastructure does not match the legitimate organisation, checking SPF, DKIM, and DMARC authentication results for failures. Domain-authentication failure is a direct consequence of the impersonation technique, because the actor fabricated sender identities rather than compromising legitimate mail infrastructure. This maps to ATT&CK T1566.001 (Spearphishing Attachment) and T1584 (Compromise Infrastructure) and is captured in the rule file `02-uat-11985-spoofed-taiwan-research-organization-ema.yml`.

Browser WebSocket connection to non-Google host. The phishing kit uses WebSocket as a persistent, low-latency C2 channel to stream real-time MFA challenge instructions to the phishing page. The source states that “the C2 server streams real-time instructions to the phishing page via this channel, dictating exactly which MFA challenge screen to render.” A browser-initiated WebSocket (wss://) connection to a host that is not a known, high-reputation service is a direct consequence of the dual-channel architecture. Defenders with access to proxy logs, DNS logs, or endpoint network telemetry can hunt for outbound WebSocket connections from user browsers to newly-seen or low-reputation hosts. This maps to ATT&CK T1566 (Phishing) with real-time relay

and is captured in the rule file `03-uat-11985-browser-websocket-to-non-google-host.yml`.

Obfuscated JavaScript with Base64 string array and while-loop shuffle. The source describes the malicious JavaScript as embedded at the end of the HTML document, leveraging "a large, static array of Base64 encoded strings coupled with control flow obfuscation" and utilising "a while(!![]) { push/shift } shuffle loop mechanism, the array rotation is resolved dynamically at runtime." This obfuscation is embedded in the kit itself to thwart static analysis, making it a structural consequence of the kit design rather than a per-deployment decision. Defenders with access to web proxy logs with content inspection or sandbox detonation can hunt for HTML pages ending with a script block containing a large static array of Base64-encoded strings and a while-loop shuffle. This maps to ATT&CK T1027 (Obfuscated Files or Information) and is captured in the rule file `04-uat-11985-javascript-obfuscation-pattern-in-html.yml`.

HTTP POST to actor C2 with specific endpoint names. The source identifies specific endpoint names hardcoded in the phishing kit's exfiltration logic: "google_login_start," "google_input_identifier," and "google_login_check." The phishing page sends browser fingerprints, credentials, and challenge submissions to the actor's HTTP C2 server through these endpoints. Their presence on non-Google infrastructure is a structural consequence of the kit design. Defenders with access to proxy logs or web firewall logs can alert on HTTP POST requests containing these paths or parameters sent to a non-Google host. However, these endpoint names are specific to this kit and could be trivially renamed in a new version, so they should be treated as fragile indicators. This opportunity is referenced in the rule file `01-uat-11985-phishing-kit-c2-endpoints.yml`.

Modified QR code in event poster attachment. The actor attached event posters to phishing emails where the poster designs were scraped from legitimate websites but the embedded QR codes were maliciously altered. A defender with email security gateway capabilities supporting image and QR code analysis can detect attached images containing QR codes whose resolved URL differs from the legitimate event registration URL, or any QR code in an attachment resolving to a non-event domain. Endpoint browser logs after a QR code scan may also reveal the divergence. This is a structural consequence of the technique because the actor modified legitimate posters with malicious QR codes as a calculated expansion of the attack surface. This maps to ATT&CK T1566.002 (Spearphishing Link) and the quishing variant. Not all email security gateways support image analysis capability, so this detection may not be available in all environments.

Spoofed Google login page with restricted locale set. The spoofed Google login panels only support Simplified Chinese, Traditional Chinese, and English locales, with region detection based on the victim's browser navigator.languages. A defender with access to web filtering logs, passive DNS, or threat-intel enrichment can hunt for a non-Google host serving a pixel-perfect Google sign-in page whose locale detection is limited to these three languages. The restricted locale set is a built-in property of the phishing kit rather than an operator choice. However, this is a hunt signal rather than a high-fidelity alert, because legitimate Google login pages served through proxies or CDNs can also show restricted locale sets.

What cannot be detected

Several critical aspects of this campaign are invisible to defenders relying solely on network and email telemetry.

The actual content of the AitM relay session between the phishing page and the real Google au-

thentication servers is inside TLS and invisible to a third-party network defender. Valid Google credentials and MFA challenges submitted by the victim pass through the actor's relay to legitimate Google infrastructure, so a successful authentication looks like a normal login from the perspective of the identity provider unless session geography, device, or token-reuse telemetry raises an anomaly. Detecting a stolen live session token requires Google Workspace or identity-provider session telemetry, such as geolocation anomaly detection, concurrent session monitoring, or token reuse from a new device. This is outside the network and email telemetry described in the source.

The AI-assisted nature of the lure content is an inference, not a directly observable signal. The source itself states that it "cannot conclusively determine whether the emails were fully generated by a large language model" and that "linguistic indicators alone cannot conclusively prove the use of generative AI." The formulaic prose, grandiose terminology, and interchangeable flattery described in the source are weak signals on their own. A defender should not build alerts on linguistic style alone, because these characteristics are shared with human-authored social engineering content and are not unique to generative AI output.

Printed QR-code posters in the physical world are outside email and network telemetry. The source describes a scenario where recipients might print and display maliciously altered posters on office bulletin boards, tricking other individuals into scanning the QR code. Once a poster is printed and displayed physically, no network or email telemetry can observe the secondary victim scanning the code. Detection of this vector requires endpoint browser logs after the scan occurs, by which point the victim may already be on the phishing page.

The developer attribution to a native Simplified Chinese speaker, while analytically valuable, is not a network-detectable signal. Talos based this assessment on the kit's localisation architecture, the base translation object written in Simplified Chinese, and lexical choices characteristic of mainland Chinese usage. These are properties of the source code and content, not of network traffic. A defender cannot observe the internal structure of the translation object or the ternary-fallback ordering through network telemetry.

The actor's use of legitimate event details as "legitimacy laundering" is not directly detectable. The source notes that "although much of this information appears to have been copied from legitimate institutional websites or public event announcements, its accuracy does not validate the email or the sender." A defender cannot distinguish between a legitimate event invitation containing accurate event details and a phishing email containing the same details copied from public sources, unless the sender domain authentication fails or the embedded hyperlinks reveal a mismatch.

Limitations

This working paper is a machine draft produced from the source text and the checked assessment. No telemetry was available for analysis, and no detections were reproduced or tested against real data. The four Sigma rules named in the detection pack are untested against live traffic and may produce false positives or miss variants of the kit that employ different endpoint names, different obfuscation patterns, or different communication architectures.

The source does not list individual IPs, domains, or URLs inline. It directs readers to a GitHub repository for the full IOC set, but this working paper does not access that repository. Any atomic indicators referenced in the rules must be populated from the GitHub repository by the defender before deployment.

The WebSocket and HTTP POST detections will fire on any AitM kit using a similar dual-channel

architecture, not just UAT-11985. Defenders should tune these detections for non-Google destinations to reduce noise from legitimate WebSocket traffic to known, high-reputation services.

The endpoint names "google_login_start," "google_input_identifier," and "google_login_check" are specific to this kit but could be trivially renamed in a new version. They should be treated as fragile indicators that may lose efficacy as the kit evolves.

QR-code detection requires image analysis capability in the mail pipeline. Not all email security gateways support this functionality, and the detection may not be feasible in environments lacking such capability.

The zh-CN, zh-TW, and en locale restriction is a hunt signal, not a high-fidelity alert. Legitimate Google login pages served through proxies or CDNs can also show restricted locale sets, and combining this signal with the Google-impersonation signal is necessary to improve precision.

The obfuscation pattern involving a Base64 string array and while-loop shuffle is common across many JavaScript phishing kits and malware loaders. Combining this signal with the Google-impersonation signal is necessary to reduce false positives.

Session-token theft is the ultimate impact of this campaign, but detecting a stolen live token requires identity-provider session telemetry that is outside the network and email telemetry described in the source. Defenders should integrate with Google Workspace or identity-provider session monitoring to detect geolocation anomalies, concurrent sessions, and token reuse from new devices.

This paper is machine drafted and intended for review by a human editor before publication. All facts are drawn from the source text and the checked assessment. Where the source is silent, the paper states it is silent. No dates, names, numbers, indicators, or quotes have been invented.

References

https://blog.talosintelligence.com/uat-11985/